

Rayu Corp Incident Response & Tabletop Exercise Program

Prepared By: Sebastion Mauldin

Role: Cybersecurity Program Manager

Date: June 2026

Version Information

Objective	Success Metric
Improve employee security awareness	≥95% completion rate
Reduce phishing susceptibility	<5% click rate
Increase policy compliance	100% policy acknowledgment
Strengthen incident reporting	20% increase in user-reported phishing emails

Table of Contents

- 1. Executive Summary
- 2. Purpose
- 3. Objectives
- 4. Incident Classification
- 5. Incident Response Lifecycle
- 6. Incident Severity Matrix
- 7. Incident Response Roles & Responsibilities
- 8. Communication & Escalation Plan
- 9. Tabletop Exercise Program
- 10. Key Performance Indicators
- 11. Continuous Improvement
- 12. Appendix

1. Executive Summary

Rayu Corp recognizes that cybersecurity incidents are inevitable. The organization's ability to detect, respond to, contain, eradicate, and recover from those incidents is critical to protecting business operations, customer trust, and organizational reputation.

This Incident Response & Tabletop Exercise Program establishes a standardized framework for responding to cybersecurity events while ensuring continuous improvement through annual tabletop exercises, lessons learned reviews, and executive reporting.

The program aligns with the Enterprise Security Modernization Initiative and supports Rayu Corp's governance, risk management, and compliance objectives.

2. Purpose

The purpose of this program is to:

- Establish a repeatable incident response process.
- Minimize business disruption.
- Reduce recovery time.
- Protect sensitive information.
- Improve organizational resilience.
- Validate response procedures through tabletop exercises.

3. Program Objectives

Objective	Success Metric
Detect incidents quickly	Mean Time to Detect (MTTD) < 4 hours
Respond rapidly	Mean Time to Respond (MTTR) < 4 hours
Contain incidents	Containment within 8 hours for High/Critical incidents
Recover business operations	Recovery within established Recovery Time Objectives (RTOs)
Test preparedness	Two tabletop exercises annually

4. Incident Classification

Incident Type	Examples
Malware	Ransomware, trojans, spyware
Phishing	Credential harvesting, business email compromise
Unauthorized Access	Account compromise, privilege escalation
Data Breach	Customer or employee data exposure
Denial of Service	Service outages, DDoS attacks
Insider Threat	Malicious or accidental insider activity
Cloud Security Incident	Misconfigured cloud storage, exposed resources

5. Incident Response Lifecycle

The incident response process follows the NIST incident handling lifecycle.

Phase 1 – Preparation

- Security awareness training
- Incident response plan maintenance
- Tabletop exercises
- Logging and monitoring
- Contact list updates

Phase 2 – Detection & Analysis

- Security monitoring
- Alert validation
- Threat intelligence review
- Incident classification
- Severity determination

Phase 3 – Containment

- Isolate affected systems
- Disable compromised accounts
- Preserve forensic evidence
- Block malicious activity

Phase 4 – Eradication

- Remove malware
- Patch vulnerabilities
- Reset credentials
- Validate system integrity

Phase 5 – Recovery

- Restore services
- Validate business operations
- Monitor for recurrence
- Communicate recovery status

Phase 6 – Lessons Learned

- Conduct post-incident review
- Document root cause
- Identify process improvements
- Update playbooks and procedures

6. Incident Severity Matrix

Severity	Description	Examples	Target Response Time
Critical	Enterprise-wide outage or confirmed data breach	Ransomware affecting production systems	1 Hour
High	Significant disruption to critical services	Privileged account compromise	2 Hours
Medium	Limited operational impact	Malware on a single endpoint	4 hours
Low	Minimal business impact	Suspicious email reported by employee	1 Business Day

7. Incident Response Roles & Responsibilities

Role	Responsibilities
Cybersecurity Program Manager	Oversees incident response program, executive reporting, and post-incident reviews
Security Operations Lead	Coordinates technical response activities
IT Infrastructure Manager	Restores affected systems and services
Legal Counsel	Advises on regulatory and legal obligations
HR Director	Coordinates employee communications when required
Communications Manager	Manages external communications and media inquiries
Executive Leadership	Makes strategic decisions during major incidents

8. Communication & Escalation Plan

Incident Severity	Notification Timeline	Stakeholders
Critical	Within 30 Minutes	Executive Leadership, Legal, IT, Communications
High	Within 1 Hour	IT Leadership, Security Team
Medium	Within 4 Hours	IT Management
Low	Next Business Day	Appropriate Department Manager

Communication channels include:

- Microsoft Teams
- Email
- Phone
- Emergency Notification System

9. Tabletop Exercise Program

Purpose

Tabletop exercises validate the effectiveness of incident response plans, improve cross-functional coordination, and identify opportunities for process improvement.

Exercise Frequency

- Two exercises per year

Participants

- Executive Leadership
- IT
- Security
- Legal
- HR
- Communications
- Business Unit Leaders

Exercise Scenarios

Scenario	Objective
Ransomware Attack	Test executive decision-making and recovery processes
Business Email Compromise	Validate financial fraud response procedures
Cloud Data Exposure	Evaluate cloud incident response and customer notification
Third-Party Vendor Breach	Assess vendor communication and business continuity

Exercise Deliverables

- Exercise Agenda
- Participant Attendance
- Facilitator Guide
- Observation Log
- Lessons Learned Report
- Corrective Action Plan

10. Key Performance Indicators

KPI	Target
Mean Time to Detect (MTTD)	<4 Hours
Mean Time to Respond (MTTR)	<4 Hours
Mean Time to Recover (MTTRc)	<24 Hours
Tabletop Exercises Completed	2 Annually
Corrective Actions Completed	≥95%
Executive Participation	100%

11. Continuous Improvement

Following each incident or tabletop exercise:

- Conduct after-action review
- Update incident response documentation
- Revise response playbooks
- Track corrective actions
- Report findings to executive leadership
- Update training materials

Program effectiveness will be reviewed annually to ensure continued alignment with organizational objectives and emerging cybersecurity threats.

12. Appendix

Related Documents

- Enterprise Risk Register
- Vendor Risk Assessment
- Security Awareness Program
- Cybersecurity KPI Dashboard
- Strategic Roadmap
- Program Charter
- Business Case

Framework References

- NIST SP 800-61 Rev. 2
- NIST Cybersecurity Framework
- CIS Controls v8
- ISO/IEC 27035